

CYBER BOOTCAMP
UNIVERSIDAD CARLOS III DE MADRID

INTRODUCCIÓN A LA CIBERSEGURIDAD

Vulnerabilidades

PRESENTADO POR: ENTIDAD: MÓDULO:
Arturo Ribagorda Gamacho Universidad Carlos III de Madrid Básico

VULNERABILIDADES

CAUSAS

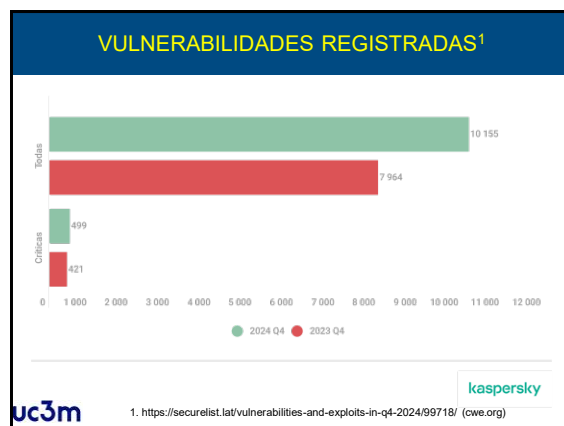
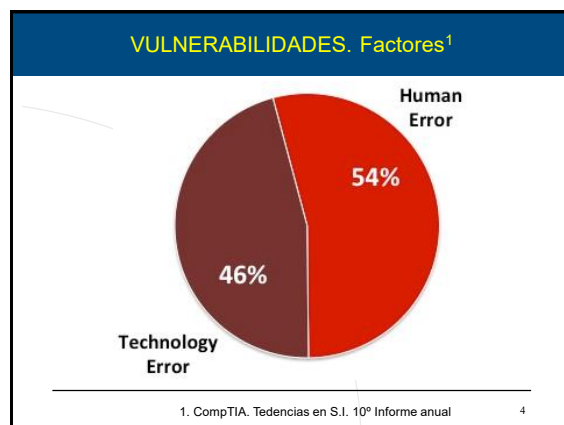
- Requisitos o diseño incorrectos, inadecuados o incompletos
- Desarrollo o implementación erróneos o no ajustados al diseño
- Operación negligente

VULNERABILIDADES¹

- Over 90% of software security incidents are caused by attackers **exploiting known software defects**
- 70% of security defects were design defects (analysis of 45 e-business applications)
- Experienced software engineers inject, on average, **one defect** every nine lines of code
- Each 10^6 line of code systems typically contains 10^3 - $1,5 \cdot 10^3$ **defects when shipped**

<http://www.sei.cmu.edu/tsp/research/index.cfm>

3



VULNERABILIDADES TOTALES Y CRÍTICAS REGISTRADAS. EXPLOITS DISPONIBLES¹



uc3m

kaspersky

1. <https://securelist.lat/vulnerabilities-and-exploits-in-q4-2024/99718/> (cwe.org)

USUARIOS DE WINDOWS QUE EMPLEARON EXPLOITS EN LOS DOS ÚLTIMOS AÑOS



uc3m

kaspersky

VULNERABILIDADES. Actualización software

Estimado cliente,

Hoy Microsoft tuvo conocimiento de la disponibilidad de código en Internet que tiene como objetivo aprovechar las vulnerabilidades publicadas en el boletín de seguridad del pasado 13 de Abril. Probablemente, usted o alguien de su compañía recibiera dicho boletín, anunciando las actualizaciones de seguridad.

Nos ponemos nuevamente en contacto con usted para asegurarnos de que cuenta con la información y con los recursos necesarios para afrontar cualquier incidencia de seguridad que pudiera surgir. Si usted todavía está evaluando estas actualizaciones, le recomendamos que acelere dicho proceso de análisis y las instale de manera inmediata. (23 de Abril de 2004)

uc3m

EMPLEADOS NEGLIGENTES. Actualización software¹



Intrusiones explotan vulnerabilidades corregidas

1. Fuente: CERT

EMPRESAS COMPRADORAS DE VULNERABILIDADES (Bug bounty programs)

La recompensa depende de:

- **Gravedad** de la vulnerabilidad (según estándares como CVSS).
- **Tipo de producto afectado** (S.O., aplicación web).
- **Impacto** (ejecución remota de código, elevación de privilegios, acceso a datos sensibles, etc.)
- Política interna de la empresa

12

EMPRESAS COMPRADORAS DE VULNERABILIDADES. Recompensas

Google (Android, Chrome, etc.)

- De 500 a más de 250000

Apple (iOS, macOS, etc.)

- Hasta 1,000,000 US (vulnerabilidades críticas tipo "zero-click")
- Otras 25,000 a 500,000

Microsoft (Windows, Azure, Office, etc.)

- De 500 a 250,000 (ejecución remota de código en Windows puede superar 100,000)
- Azure hasta 300,000 USD

EMPRESAS COMPRADORAS DE VULNERABILIDADES. Recompensas

- Meta (Facebook, Instagram, WhatsApp)
 - De 500 a 100 000
- Intel
 - Hasta 100 000 US (vulnerabilidades críticas)
- IBM, Oracle, SAP, etc. o también tienen programas de recompensa o colaboran con plataformas de recompensas

24

EMPRESAS PROPORCIONAN ALTERNATIVIDADES

Microsoft ofrece recompensa para capturar a dos creadores de virus

Dará medio millón de dólares por pistas del 'SoBig' y el 'Blaster'

ANTWERP, Bélgica. El sector laboral todavía activo en EE UU—tienen desde aquí un nuevo objetivo: capturar a los programadores informáticos que están detrás de los

peores virus que afectan al sistema operativo Windows. La compañía Microsoft ha anunciado que reserva cinco millones de dólares para gratificar a quienes delaten a los autores de los virus, entre ellos los del *Blaster*.

La recompensa, superior a la que ofrece el FBI por algunos de los terroristas más buscados, es la primera que se ofrece por la captura de un delincuente informático. Microsoft ha puesto el dinero encima de la mesa después de consultar con el FBI y el Servicio Secreto de EE UU, encargados de investigar la *cyberdelincuencia*.

Internet, cibercréditos o delitos virtuales: son delitos reales que dañan a mucha gente. Quienes liberan los virus son subcontratistas del cibercrimen, y Microsoft quiere ayudar a las autoridades a capturarlos", dijo Smith en Washington.

No por casualidad, el anuncio coincide con los flecos legales del caso *Microsoft's* los pro-

ra atacar las páginas de actualización de programas de Microsoft. Al final, la información generaba tal flujo de sucesos que las redes quedaban bloqueadas por la avalancha.

El *SoBig* es un virus que se extendió rápidamente en cientos de miles de correo electrónico. Estaba diseñado para convertir los ordenadores "atrapa-

—

El País, 6 de noviembre de 2003

EMPRESAS COMPRADORAS DE VULNERABILIDADES (*Bug bounty programs*)

- Zero Day Initiative (Trend Micro)
- HackerOne
- Bugcrowd
- Synack
- YesWeHack
- ...

16

[illegible]

VULNERABILIDADES. Denominación

DENOMINACIÓN E INTERCAMBIO INFORMACIÓN

- CVE (Common vulnerabilities and exposures)
- CWE (Common weakness enumeration)
- CAPEC (Common Attack Pattern Enumeration and Classification)
- ITU-T Recomendación X.1520 (04/2011)

19

DESCUBRIMIENTO DE VULNERABILIDADES

- Análisis de vulnerabilidades
- Pruebas de penetración



INTRODUCCIÓN A LA CIBERSEGURIDAD

Vulnerabilidades

PRESENTADO POR:	ENTIDAD	MÓDULO
Arturo Ribagorda Gamacho	Universidad Carlos III de Madrid	Básico